COMPTIA SECURITY+ SY0-701 | DOMAIN 3 · SECURITY ARCHITECTURE (18%)

Security+ 3.3 · States of Data

Mestre CyberSec · **Lesson 3.3 — States of Data** (6:07) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: 3 estados: AT REST (parado no disco — BitLocker/DEB); IN TRANSIT (viajando — TLS/VPN); IN USE (sendo processado na memória — confidential computing/enclaves). O mais difícil de proteger é o in use.

💡 Key Exam Highlights & Critical Concepts

- At rest: disco; In transit: rede; In use: memória
- TLS=transit; BitLocker=TDE+rest; enclaves=use

🎯 Exam Tips & Typical CompTIA Scenarios

- 'data being processed in memory'=in use

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 3.3 — States of Data)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Data at Rest (DAR)
Data stored on a physical medium such as a disk, database, or backup and not currently moving across a network or being processed in memory. Protect it with encryption, access controls, and secure disposal.

⚠️ ***Exam Trap:*** *Se a questão falar de disco, arquivo salvo, banco de dados ou backup, é at rest. BitLocker/FDE e TDE são controles típicos.*

• Data in Transit (DIT)
Data moving across a network between systems, applications, or users. Protect it with TLS, VPN, SSH, or IPsec.

⚠️ ***Exam Trap:*** *Se mencionar rede, tráfego, HTTP/HTTPS, e-mail ou VPN, é in transit. TLS protege trânsito, não repouso.*

• Data in Use (DIU)
Data currently being processed in memory by a CPU, application, or runtime. It is considered the hardest state to protect and may require confidential computing or secure enclaves.

⚠️ ***Exam Trap:*** *Palavra-chave 'processed in memory' = in use. Não confunda com at rest (disco) nem in transit (rede).*

• Full Disk Encryption (FDE)
Encrypts an entire storage device so all data at rest is protected if the device is lost or stolen. BitLocker is a common Windows implementation.

⚠️ ***Exam Trap:*** *FDE/BitLocker = at rest. Não protege dados em uso depois que o sistema está ligado e desbloqueado.*

• BitLocker (N/A)
Microsoft Windows full volume encryption feature that protects data at rest, often using TPM for key protection. It is a common example of full disk encryption.

⚠️ ***Exam Trap:*** *Se a prova citar BitLocker, pense at rest/FDE no disco. Pode usar TPM para armazenar chaves.*

• Transport Layer Security (TLS)
Cryptographic protocol that provides encryption and integrity for data in transit between clients and servers, commonly used by HTTPS. It does not protect data at rest or in use.

⚠️ ***Exam Trap:*** *TLS = in transit. HTTPS usa TLS. Não é criptografia de disco nem de memória.*

• **Virtual Private Network (VPN)**

Creates an encrypted tunnel for data in transit over an untrusted network such as the Internet. It protects network traffic, not data stored on endpoints.

⚠️ ***Exam Trap:*** *VPN = in transit. Protege tráfego de rede, não dados parados no disco.*

• **Confidential Computing / Secure Enclave (N/A)**

Protects data in use by isolating processing inside a hardware-based trusted execution environment or enclave. It prevents the host OS or other processes from accessing data while it is being processed.

⚠️ ***Exam Trap:*** *Enclaves/confidential computing = in use. Se mencionar dados em processamento na memória, escolha in use.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Data at Rest (DAR - Storage Tier)

🏠 **Real-World Analogy:** A gold bullion stored inside a subterranean steel safe in a bank's vault. It is not traveling down a highway, nor is it being smelted by a jeweler at that exact second; it simply rests in place. However, if a thief breaks into the facility overnight and the vault door was left unbolted (unencrypted storage drives), they effortlessly carry the gold away.

🔍 **Root Cause & Background:** Physical storage hardware (corporate laptops, thumb drives, decommissioned backup tapes, and server SAS drives) is routinely misplaced in airport cabs, stolen from parked cars, or discarded in waste bins without cryptographic sanitization.

🛡️ **GRC Auditor Perspective:** Enforcing Full Disk Encryption (FDE via BitLocker/FileVault) across 100% of mobile endpoints bound to hardware TPM chips; deploying SED (Self-Encrypting Drives) in SANs; and requiring certified degaussing and mechanical shredding for retired drives.

⚠️ **How CompTIA Tests This:** Exam trigger: 'laptop stolen from an employee vehicle; organization incurs no breach notification penalties because all drives utilized Full Disk Encryption (FDE)' = Data at Rest. Also: 'securing databases stored on SAN arrays or magnetic archives'.

📌 Data in Transit / In Flight (DIT - Network Tier)

🏠 **Real-World Analogy:** A motorcycle courier transporting confidential executive documents through heavy downtown traffic. If the papers are inside a clear plastic sleeve (cleartext protocols like HTTP, Telnet, FTP), every passerby and taxi driver reads them at the stoplight. If sealed in an armored titanium dispatch case with an electronic combination lock (encrypted TLS or IPsec VPN tunnel), no eavesdropper can intercept or alter them.

🔍 **Root Cause & Background:** Computer networks—especially open coffee shop Wi-Fi hotspots and public internet transit hops—are shared media vulnerable to packet sniffing, ARP cache poisoning, and active On-path (Man-in-the-Middle) payload tampering.

🛡️ **GRC Auditor Perspective:** Mandating the immediate retirement of legacy cleartext protocols (blocking ports 80/HTTP, 21/FTP, 23/Telnet via perimeter firewalls); enforcing TLS 1.3 across corporate web endpoints; and requiring MFA-gated encrypted VPN tunnels for remote staff.

⚠️ **How CompTIA Tests This:** Exam trigger: 'prevent network eavesdropping, packet sniffing, or session hijacking over unsecured transit paths' = Data in Transit / TLS / IPsec / SSH. Exam trap: traffic between internal virtual switches or VPC subnets is still categorized as 'in transit'.

📌 Data in Use / In Processing (DIU - Memory & Execution Tier)

🏠 **Real-World Analogy:** A master chef preparing a delicate dish with the secret recipe sheet unfolded on the stainless steel prep counter. While ingredients are actively cooking in the pan (processed by the CPU) and the recipe lies open (loaded in volatile RAM), anyone walking into the kitchen can glance at the formula or tamper with the pan, regardless of whether the pantry cabinet was padlocked.

🔍 **Root Cause & Background:** Modern microprocessors require data to be decrypted into plain text within volatile system RAM and CPU registers during computation, leaving sensitive payloads exposed to rootkits, memory dumping utilities (e.g., Mimikatz), and POS RAM scrapers.

🛡️ **GRC Auditor Perspective:** Auditing advanced memory protection baselines: Confidential Computing architectures, hardware-enforced Secure Enclaves (e.g., Intel SGX, AMD SEV), blocking unauthorized debug/memory dump hooks, and enabling Windows Defender Credential Guard.

⚠️ **How CompTIA Tests This:** Exam trigger: 'data actively resident in system RAM, CPU registers, or cache while being executed by an application' = Data in Use. Modern CompTIA SY0-701 defense benchmark: Confidential Computing / Hardware Secure Enclaves.

📌 Holistic GRC Governance Across All Data States (Data Defense-in-Depth)

🏠 **Real-World Analogy:** An armored bullion logistics operation: the reinforced subterranean vault secures the stationary currency (DAR); the bulletproof convoy with armed outriders secures it along highway corridors (DIT); and the sealed biometric room with overhead surveillance secures it while cashiers count notes on the table (DIU). Failing at any single tier guarantees total robbery.

🔍 **Root Cause & Background:** The classic security fallacy where an enterprise expends its entire budget on SSL/TLS network channels (DIT), leaving SQL database storage unencrypted on disk (DAR), or permitting technicians to export raw memory dumps to unprotected shared folders (DIU).

🛡️ **GRC Auditor Perspective:** Verifying formal Data Lifecycle Flowcharts within SOC 2 Type II and ISO 27001 audits; confirming that enterprise risk assessments explicitly address and mitigate vulnerabilities across all three phases simultaneously.

⚠️ **How CompTIA Tests This:** Exam trigger: 'comprehensive data protection framework requires technical safeguards across every phase of the information lifecycle'. Identify the three states: Data at Rest, Data in Transit, and Data in Use.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Corporate laptop stolen from employee vehicle containing client SQLite databases on the internal drive	**Data at Rest (DAR) mitigated by BitLocker / Full Disk Encryption (FDE)**
Sniffing authentication credentials and bank transfers across an unencrypted airport Wi-Fi hotspot	**Data in Transit (DIT) mitigated by TLS 1.3 / IPsec VPN**
RAM scraper malware hooked into point-of-sale memory extracting raw PAN card numbers during transaction compute	**Data in Use (DIU) mitigated by Confidential Computing / Secure Enclaves**
Safeguard ensuring discarded SAS hard drives cannot be forensically reassembled to extract corporate trade secrets	**Media Sanitization at Rest (Degaussing / Purging / Physical Shredding)**
Hardware-isolated cryptographic perimeter shielding executing runtime code from an untrusted underlying OS	**Hardware Secure Enclave / TPM (Confidential Computing)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A hospital issues laptops to nurses. One laptop containing patient records is stolen from a locked car. The security team must ensure that if the drive is removed and connected to another computer, the stored records remain unreadable. Which control best addresses this requirement?

A) TLS session encryption for the electronic health record portal

B) VPN tunnel for remote access to the hospital network

C) Secure enclave for processing patient records in memory

D) Full disk encryption such as BitLocker

QUESTION 2 · EXAM SCENARIO

A retail company's online checkout sends payment card data from customers' browsers to its web servers over the public internet. The security architect wants to prevent eavesdropping and tampering during transmission. Which technology should be implemented?

A) Full disk encryption on the web servers

B) Column-level encryption in the payment database

C) Transport Layer Security (TLS)

D) A secure enclave on the application server

QUESTION 3 · EXAM SCENARIO

A financial analyst works from a coffee shop and needs to access internal file shares containing quarterly reports. The company requires that the traffic between the analyst's laptop and the corporate network be encrypted across the untrusted public Wi-Fi. Which solution best meets this requirement?

A) BitLocker To Go on the laptop's USB ports

B) A VPN connection to the corporate network

C) Database transparent data encryption on the file server

D) Memory encryption for the analyst's spreadsheet application

QUESTION 4 · EXAM SCENARIO

A cloud provider runs multiple customers' workloads on the same physical host. A regulated customer wants assurance that its data cannot be viewed by the hypervisor administrator while the workload is actively processing in memory. Which approach best addresses this concern?

A) Encrypting the virtual disk with BitLocker

B) Requiring TLS for all management console sessions

C) Using confidential computing with hardware-based secure enclaves

D) Storing backups in an encrypted S3 bucket

QUESTION 5 · EXAM SCENARIO

A CISO is prioritizing security investments across the data lifecycle. The team notes that some controls protect stored files, others protect network sessions, and others protect information while applications and CPUs are actively working on it. Which data state is generally the most difficult to protect because it must be exposed in memory for processing?

A) Data at rest

B) Data in transit

C) Data in use

D) Data in archive

QUESTION 6 · EXAM SCENARIO

An e-commerce company stores its customer database on a storage area network. An attacker gains physical access to the data center and steals several disk drives. The company wants to ensure the database files cannot be read when the drives are attached to another system. Which control is most appropriate?

A) TLS mutual authentication between database nodes

B) VPN access for database administrators

C) Full disk encryption on the storage volumes

D) A trusted execution environment for database queries

QUESTION 7 · EXAM SCENARIO

A microservices architecture sends authentication tokens and personal data between internal services inside a Kubernetes cluster. The security team is concerned about lateral movement and man-in-the-middle attacks between services, even though the traffic stays inside the data center. Which control best protects this traffic?

A) Full disk encryption on worker node volumes

B) Mutual TLS (mTLS) between services

C) Secure enclaves for each container's memory

D) BitLocker To Go on administrator laptops

QUESTION 8 · EXAM SCENARIO

An HR employee copies a spreadsheet containing employee salaries to a USB flash drive to work on it at home. The drive is later lost. The company wants to reduce the risk that anyone who finds the drive can read the spreadsheet. Which control should be applied to the USB drive?

A) TLS for file transfers

B) VPN on the employee's home router

C) BitLocker To Go with a strong password or smart card

D) A secure enclave on the employee's laptop

QUESTION 9 · EXAM SCENARIO

A key management service must process cryptographic keys in memory to perform signing operations. The security team is worried that a malicious administrator or malware could dump process memory and extract the keys. Which technology best protects the keys while they are being used?

A) Hardware-based secure enclave or confidential computing environment

B) Full disk encryption on the key management server

C) TLS for all administrative connections

D) RAID 6 on the key management server's disks

QUESTION 10 · EXAM SCENARIO

A company sends nightly payroll files from its headquarters to a payroll processor over the internet. The payroll processor must be able to verify that the files were not modified during transmission and that they came from the company. Which control best provides these protections for the data while it is moving?

A) Full disk encryption on both organizations' servers

B) TLS with server and client certificates

C) Secure enclaves on the payroll processing servers

D) Database encryption at rest at the payroll processor

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option D — Full disk encryption such as BitLocker

The risk is data at rest on a stolen drive. Full disk encryption such as BitLocker encrypts the entire volume so that patient records remain unreadable if the drive is removed and attached to another system. TLS and VPN protect data in transit, while a secure enclave protects data in use in memory.

Question 2: Option C — Transport Layer Security (TLS)

TLS protects data in transit by encrypting web traffic and helping detect tampering between the browser and the server. Full disk encryption and column-level encryption protect data at rest, while a secure enclave protects data in use during processing.

Question 3: Option B — A VPN connection to the corporate network

A VPN encrypts data in transit across untrusted networks such as public Wi-Fi. BitLocker To Go and transparent data encryption protect data at rest, while memory encryption addresses data in use.

Question 4: Option C — Using confidential computing with hardware-based secure enclaves

The concern is data in use while it is actively processed in memory. Confidential computing with hardware-based secure enclaves isolates memory from the hypervisor and other tenants. BitLocker and encrypted backups protect data at rest, and TLS protects data in transit.

Question 5: Option C — Data in use

Data in use is generally the most difficult state to protect because it must be decrypted and available in memory or CPU registers for processing. Data at rest and data in transit can often be protected with mature encryption technologies, and archived data is a form of data at rest.

Question 6: Option C — Full disk encryption on the storage volumes

Stolen disk drives represent data at rest. Full disk encryption on the storage volumes keeps database files unreadable when the drives are attached to another system. TLS and VPN protect data in transit, and a trusted execution environment protects data in use.

Question 7: Option B — Mutual TLS (mTLS) between services

Service-to-service traffic is data in transit, even inside the data center. Mutual TLS encrypts the traffic and authenticates both services, helping prevent man-in-the-middle and lateral movement attacks. Full disk encryption protects data at rest, and secure enclaves protect data in use.

Question 8: Option C — BitLocker To Go with a strong password or smart card

The spreadsheet on the USB drive is data at rest. BitLocker To Go encrypts removable media and requires authentication, reducing the risk of unauthorized reading if the drive is lost. TLS and VPN protect data in transit, and a secure enclave protects data in use.

Question 9: Option A — Hardware-based secure enclave or confidential computing environment

Keys being processed in memory are data in use. A hardware-based secure enclave or confidential computing environment isolates memory and helps prevent even privileged administrators or malware from extracting keys during processing. Full disk encryption protects data at rest, TLS protects data in transit, and RAID 6 addresses availability.

Question 10: Option B — TLS with server and client certificates

The requirement is to protect data in transit with integrity and source authentication. TLS with server and client certificates encrypts the transfer and uses certificates to authenticate both parties and detect modification. Full disk encryption and database encryption protect data at rest, while secure enclaves protect data in use.